

Preston-Check — Enterprise Security Audit Suite

The Most Comprehensive Security Audit for Financial Platforms

Bloxcross Financial Infrastructure Security

2026

Preston-Check Enterprise Security Audit Suite v2.0

The Most Comprehensive Security Audit for Financial Platforms

56 check categories | 131 individual tests | 10 security themes | < 2 minutes runtime

Built from real attack forensics. Named after Preston Braswell, a hacker who created 5+ fake accounts, bypassed 2FA, ran 21,201 automated session polling calls, and probed for race conditions on a production fintech platform. Every check is derived from a real vulnerability.

What Makes Preston-Check Different

Finance-Native: Checks for BigDecimal enforcement, rounding modes, double-spend prevention, crypto AML screening, Fireblocks co-signer integration — things generic security tools don't know about.

Attack-Tested: Every check maps to a real attack pattern from forensic analysis of 12.3M log lines. Not theoretical — proven against actual hacker behavior.

Compliance-Ready: Covers SOC2, PCI-DSS, AML/BSA, GDPR, and ISO 27001 requirements. Produces audit-ready reports with remediation plans.

Virtuous Cycle: Self-improving loop: diagnose → compare → learn → propose → approve → fix → verify. Score can only go up, never regress.

Portal Integration: Full Ops Portal UI with score progression, cycle history, individual item approval, and deploy button.

Portable & Reusable: Single config.yml per project. Runs on any fintech codebase. Deploy to CI/CD in 5 minutes.

56 Check Categories

Theme 1: Core Security (P-01 to P-10) — From the Preston Attack

- P-01 Hardcoded Secrets — API keys, passwords, AWS keys in source
- P-02 2FA Bypass — Code paths that skip authentication
- P-03 Info Leakage — Exception messages in API responses
- P-04 Rate Limiting — Endpoints without request throttling
- P-05 Idempotency — Webhook replay and double-spend protection
- P-06 Session Security — IP binding, TTL, session kill capability
- P-07 Blacklist — Registration/KYC blacklist enforcement
- P-08 Input Validation — SQL injection, command injection
- P-09 Audit Trail — DB triggers, append-only ledger
- P-10 Live Attacks — Real-time brute force, polling detection

Theme 2: Platform Security (P-11 to P-20)

P-11 TLS/Encryption | P-12 Financial Guards | P-13 Auth Enforcement | P-14 Dependency Security | P-15 CORS/CSRF | P-16 Error Handling | P-17 Secure Random | P-18 Data Privacy | P-19 API Versioning | P-20 Deploy Safety

Theme 3: Compliance & Regulatory (P-21 to P-24)

- P-21 PCI-DSS Card Data — Raw PAN detection, tokenization verification
- P-22 AML Transaction Monitoring — CTR thresholds, structuring detection, SAR mechanism
- P-23 KYC Document Security — S3 encryption, presigned URL duration, file validation
- P-24 Data Retention — Redis TTL, GDPR erasure mechanism

Theme 4: Infrastructure Security (P-25 to P-28)

- P-25 AWS IAM Hygiene — Static credentials vs IAM roles, Secrets Manager
- P-26 Network Exposure — Redis auth, management ports, service binding
- P-27 TLS Certificate (Live) — Cert expiry, HSTS headers
- P-28 WAF & DDoS — WAF integration, OFAC geo-blocking

Theme 5: API Security / OWASP Top 10 (P-29 to P-34)

- P-29 Webhook Signatures — Per-handler cryptographic verification
- P-30 HMAC Integrity — Filter coverage, replay protection, algorithm strength

- P-31 BOLA Authorization — Resource IDs without ownership verification (OWASP #1)
- P-32 Mass Assignment — Raw entities as request body (OWASP #3/#6)
- P-33 Resource Limits — Body size, timeouts, pagination (OWASP #4)
- P-34 SSRF Prevention — User URLs in HTTP clients (OWASP #7)

Theme 6: Data Protection (P-35 to P-37)

- P-35 Database Encryption — SSL enforcement, SELECT * overfetching
- P-36 Key Management — Key files in repo, rotation mechanisms
- P-37 Backup & DR — Backup references, DR docs, migration rollbacks

Theme 7: Operational Security (P-38 to P-40)

- P-38 Security Logging — Login/transaction/admin action completeness
- P-39 Alerting & Monitoring — Circuit breakers, alert integration
- P-40 Incident Response — Session revocation, IR documentation

Theme 8: Supply Chain (P-41 to P-43)

- P-41 Dependency Pinning — Maven versions, npm lock files, Docker tags
- P-42 CI/CD Security — Credentials in scripts, curl|bash, SSL bypasses
- P-43 Container Security — Root containers, secrets in images

Theme 9: Mobile & Frontend (P-44 to P-49)

- P-44 Flutter/Dart Security — Hardcoded keys, cert pinning, secure storage
- P-45 Mobile Network — Android cleartext, iOS ATS
- P-46 Webhook Ordering — Event persistence, dead-letter queues
- P-47 Financial Reconciliation — External balance comparison, compensation patterns
- P-48 React Frontend — XSS vectors, localStorage tokens
- P-49 Git History Secrets — .env files, key files ever committed

Theme 10: Finance-Specific Gold Standard (P-50 to P-56)

- P-50 Transaction Integrity — BigDecimal enforcement, rounding modes, division safety
- P-51 Privilege Escalation — Unguarded role/permission mutations
- P-52 Timing Attacks — Constant-time comparison for secrets
- P-53 Account Lifecycle — Account locking, email change verification
- P-54 API Key Management — Expiration, permission scoping
- P-55 Crypto Address Security — Validation, whitelisting, AML screening (Btrace/Chainalysis)
- P-56 Multi-Signature Approval — Dual-approval workflows, Fireblocks co-signer/TAP

How It Works

```
Run:    ~/DEV/preston-check/preston-check.sh --config configs/myapp.yml
CI/CD:  ./preston-check.sh --ci --report audit-report.md
Cycle:  ~/DEV/preston-check/preston-cycle.sh --config configs/myapp.yml
```

Contact

Bloxcross Financial Infrastructure Security

security@bloxcross.com | bloxcross.com